Resultados de pruebas funcionales

SSGUI · Sistema de Solicitud de Gestión de Usuarios Interno · ANDINA S.A.S. (empresa ficticia; todos los datos son ficticios)
José Bedoya, Carlos Ruiz, Luis Cerón y Cristian Caro · Institución Universitaria Politécnico Grancolombiano · Taller de Desarrollo Seguro de Software · Grupo G01
Docente: José Eduardo Patiño Santafé · Entregable 1 de 4 · 25 de octubre de 2026

1. Objetivo y resumen

Este documento presenta los resultados de las pruebas funcionales del sistema SSGUI, con énfasis en las **pruebas de casos de uso**. El objetivo es demostrar que el sistema cumple las funciones especificadas en el documento de requisitos (SRS, versión 2.5) y que los flujos de negocio funcionan de extremo a extremo, desde la interfaz web hasta los tickets en GLPI.

Las pruebas combinan dos niveles complementarios. El primero es una **suite automatizada** de 2 574 pruebas que verifica reglas, casos de uso, contratos entre componentes y adaptadores. El segundo es el **recorrido de los casos de uso a través del cortafuegos de aplicaciones web (WAF)**, con un navegador real y contra GLPI 11, que confirma que esas reglas se sostienen en el sistema desplegado.

Tabla 1. Resumen de resultados

Indicador	Resultado
Suite automatizada sin integración	2 574 pruebas aprobadas; 2 omitidas con justificación; 1 fallo esperado documentado
Pruebas de integración con PostgreSQL 17	251 aprobadas; 18 omitidas por requerir el servicio externo de autenticación
Pruebas contra GLPI 11 real	30 de 30 aprobadas
Casos de uso ejecutados a través del WAF con navegador	4 de 4 (ingreso, vacaciones, retiro y emergencia)
Criterios de aceptación del SRS	21 de 21 cumplidos
Cobertura de ramas	Dominio 97,74 %; aplicación 94,83 %; módulos de seguridad 100 %
Verificación de las pruebas mediante mutación	Dominio 97,8 %; aplicación 92,7 %; módulos de seguridad 96,1 %

2. Alcance y entorno de pruebas

Alcance. Los seis tipos de evento laboral (ingreso, vacaciones, cambio de departamento, cambio de sucursal, retiro y emergencia), su registro, aprobación, emisión de tickets, sincronización, cierre y derivación del estado de las cuentas; el panel y la búsqueda para el personal técnico; la auditoría; y la administración de perfiles y roles.

Entorno. Las pruebas se ejecutaron sobre la arquitectura de referencia del proyecto, que es local: Docker Desktop con Docker Compose en la máquina del equipo, con BunkerWeb 1.6.15 como WAF, la aplicación Django 5.2 con gunicorn, un trabajador de integración, PostgreSQL 17 en contenedor como base de datos de la aplicación, y GLPI 11.0.11 con MariaDB 11.4. La instancia de GLPI y los datos de prueba eran desechables y ficticios.

Limitación del entorno. El inicio de sesión real exige contraseña y un segundo factor contra Supabase Auth, el único servicio externo de la arquitectura, que por ser de un tercero no se evaluó de forma activa. En el recorrido con navegador se crearon sesiones de prueba equivalentes a las de un usuario que ya superó el segundo factor, sin sustituir ninguna regla de autorización, que se evalúa en cada vista. El flujo de autenticación se cubre con la suite automatizada mediante un servidor de autenticación simulado.

3. Estrategia de pruebas

La estrategia aplica niveles que se refuerzan entre sí. Las reglas de negocio se verifican en un dominio puro, sin red ni base de datos; los casos de uso, con dobles en memoria; cada puerto, con una suite de contrato que el doble y el adaptador real deben superar sin modificaciones; y los flujos completos, contra los servicios reales.

Tabla 2. Niveles de prueba

Nivel	Qué verifica	Pruebas
Dominio	Reglas puras: máquina de estados, generación de tickets, auditoría encadenada, perfiles, permisos y cuentas	820
Aplicación	Casos de uso con dobles en memoria; atomicidad de las operaciones; denegaciones y rastro de auditoría	249
Contratos	Cada puerto con su doble y su adaptador real	228
Escenarios	Los seis tipos de evento completos en memoria; las tablas del Anexo A	75
Adaptadores	Vistas, persistencia, GLPI, identidad, trabajador, infraestructura y accesibilidad	439
Seguridad	Autorización por celda, IDOR y CSRF, segundo factor, soportes, filtro de registros	680
Escenarios Gherkin	13 características en español con camino feliz, caso límite y caso adversarial	83
Integración con PostgreSQL	Restricciones, disparadores, roles y concurrencia contra el motor real	251
GLPI 11 real	Contrato del adaptador y flujos contra el servicio real	30
Navegador a través del WAF	Casos de uso de ingreso, vacaciones, retiro y emergencia	4

4. Resultados de la suite automatizada

4.1 Cobertura y calidad de las pruebas

Tabla 3. Cobertura de ramas

Grupo	Ramas cubiertas	Porcentaje	Meta
Dominio	303 de 310	97,74 %	95 %
Aplicación	220 de 232	94,83 %	90 %
Adaptadores	380 de 406	93,6 %	—
Siete módulos de seguridad	164 de 164	100 %	95 %

La cobertura mide qué ramas se ejecutaron, pero no si las pruebas detectan un error. Por ello se aplicó **mutación**: se alteró el código de forma controlada y se verificó que alguna prueba fallara.

Tabla 4. Resultado de la mutación

Objetivo	Mutantes	Detectados	Porcentaje	Meta
Dominio	1 341	1 312	97,8 %	85 %
Aplicación	2 226	2 063	92,7 %	85 %
Módulos de seguridad	512	492	96,1 %	85 %

La primera medición de la aplicación fue de 77,8 %, pues las pruebas verificaban el tipo de las excepciones y las acciones registradas, pero no su contenido. Se añadieron pruebas que fijan la acción y el motivo de cada denegación, el rastro de auditoría completo de un ingreso y de un retiro, y el contenido exacto de las peticiones al servicio de identidad. Con ellas la medición subió a 92,7 %.

4.2 Estabilidad

Se ejecutaron 20 corridas consecutivas de la suite sin reintentos automáticos: las 20 finalizaron sin fallos, con 1 632 pruebas cada una.

5. Pruebas de casos de uso

5.1 Catálogo de casos de uso

Los casos de uso se tomaron de los roles y flujos del SRS. Para cada uno se indica el actor, su propósito y las pruebas que lo ejercitan.

Tabla 5. Casos de uso y pruebas asociadas

Código	Caso de uso	Actor	Propósito	Pruebas asociadas	Resultado
CU-01	Iniciar sesión con segundo factor	Cualquier usuario	Acceder tras verificar contraseña y código TOTP	110	Aprobado
CU-02	Registrar vacaciones	Colaborador	Solicitar la suspensión temporal de sus cuentas	97	Aprobado
CU-03	Rechazar una solicitud duplicada	Colaborador o RRHH	Impedir dos solicitudes abiertas del mismo tipo	10	Aprobado
CU-04	Registrar cambio de departamento o de sucursal	Jefe o RRHH	Solicitar el traslado de un subordinado	278	Aprobado
CU-05	Aprobar, rechazar o cancelar una solicitud	RRHH o solicitante	Decidir con justificación; cancelar antes de la emisión	134	Aprobado
CU-06	Emitir un ingreso con soporte de vinculación	RRHH	Crear la cuenta de una persona nueva con su documento PDF	56	Aprobado
CU-07	Emitir un retiro con motivo restringido	RRHH	Cerrar los accesos de quien se retira, sin exponer el motivo	4	Aprobado
CU-08	Emitir una emergencia	RRHH	Cerrar accesos de inmediato ante un incidente	22	Aprobado
CU-09	Consultar panel, cuentas y ficha	Personal técnico	Conocer el estado de las cuentas y de los tickets	58	Aprobado
CU-10	Controlar el acceso por rol	Todos	Negar a cada rol lo que no le corresponde	583	Aprobado
CU-11	Consultar y verificar la auditoría	Auditor	Comprobar la integridad de la cadena de registros	39	Aprobado
CU-12	Administrar perfiles y roles	Administrador	Mantener la matriz de perfiles y los roles	34	Aprobado
CU-13	Reintentar la emisión de una solicitud	Administrador	Reanudar una solicitud cuyo ticket falló	6	Aprobado
CU-14	Sincronizar tickets y cerrar la solicitud	Trabajador	Derivar el estado de las cuentas y cerrar la solicitud	76	Aprobado

Nota: la columna «Pruebas asociadas» indica el número de pruebas automáticas, a nivel de archivo o escenario, que ejercitan el caso de uso; una misma prueba puede aportar a más de un caso.

5.2 Ejecución de los casos de uso principales a través del WAF

Cuatro casos de uso se ejecutaron con un navegador real (Chromium, mediante Playwright) a través del WAF por HTTPS, contra la aplicación, el trabajador de integración y GLPI 11. Para cada uno se verificó que el formulario se envía, que la aplicación responde con el mensaje esperado y que los tickets aparecen en GLPI con la cola, la prioridad y el vencimiento correctos.

Tabla 6. Ejecución de los casos de uso con navegador

Caso	Flujo ejecutado	Resultado esperado	Resultado obtenido
CU-06 Ingreso	RRHH completa el formulario de ingreso con un PDF de 2 MB y lo envía	Solicitud emitida; 4 tickets (AD, Comunicaciones, Licencias e Inventario) con el soporte adjunto a AD y a Licencias	Aprobado
CU-02 y CU-05 Vacaciones	El colaborador registra sus vacaciones; RRHH las aprueba desde su bandeja	Solicitud «pendiente de aprobación» y luego «aprobada»; 4 tickets: suspensión en AD y en Licencias y sus reactivaciones programadas	Aprobado
CU-07 Retiro	RRHH emite un retiro por fin de contrato con un motivo restringido	Solicitud emitida; 6 tickets (2 de ellos posteriores, a 90 días); el motivo no aparece en GLPI	Aprobado
CU-08 Emergencia	RRHH emite una emergencia por fuga detectada con una descripción restringida	Solicitud emitida; 6 tickets con prioridad «Muy alta» y vencimiento de 1 hora; la descripción no aparece en GLPI	Aprobado

En cada ejecución, la vigilancia del navegador comprobó además que ninguna petición del navegador obtuviera una respuesta de error del servidor y que todos los recursos estáticos se cargaran.

Hallazgo sobre el procedimiento de prueba. Al repetir el recorrido tras restaurar la base de datos, se constató que los números de solicitud se reutilizan mientras GLPI conserva los tickets de la corrida anterior, de modo que la prueba podía aprobarse sin que se creara ningún ticket nuevo (hallazgo B-37). Para las mediciones de este documento, se purgaron los tickets sobrantes de la instancia desechable de GLPI antes de cada corrida. Además, el recorrido reveló que el limitador de frecuencia del WAF puede devolver el código 429 a una persona que navega

con rapidez (hallazgo B-36).

5.3 Escenarios de aceptación en lenguaje Gherkin

Se redactaron 13 características en español, con caminos felices y casos adversariales, y se vincularon a los requisitos y a las amenazas del modelo. Una prueba automática verifica que ninguna etiqueta quede sin trazar y que cada una de las 26 amenazas tenga al menos un escenario.

Tabla 7. Características Gherkin

Característica	Qué comprueba
Ingreso	Contraseña correcta sin segundo factor no entra; un código usado no se reutiliza
Autorización	Cada rol accede solo a sus vistas; los roles incompatibles se rechazan
Inmutabilidad (en memoria y en PostgreSQL)	Una solicitud aprobada no se modifica; la auditoría no se altera
Restringidos	El motivo y la descripción no aparecen fuera de lo permitido
Soporte PDF	Solo se aceptan PDF válidos de hasta 20 MB
Cuentas derivadas	El estado de una cuenta solo cambia con tickets resueltos con solución
Resiliencia	Una caída de GLPI no pierde ni duplica solicitudes
Cabeceras, borde, secretos y registros, base de datos aislada y cadena de suministro	Controles de la infraestructura y del borde

6. Pruebas contra GLPI 11 real

El adaptador de GLPI se verificó con 30 pruebas contra una instancia real de GLPI 11.0.11: creación de tickets con categoría, prioridad, estado y vencimiento; subida de un documento y vínculo con varios tickets; lectura del estado, de la solución y de los documentos; creación y actualización de usuarios; y lectura de activos y licencias. Además se verificó que cada ticket llega al grupo de su cola y que una categoría desconocida se enruta a «Revisión manual». Resultado: **30 de 30 aprobadas**.

7. Criterios de aceptación

Tabla 8. Criterios de aceptación del SRS

Criterio	Descripción	Resultado
CA-01	Deduplicación: el segundo intento del mismo tipo se rechaza	Cumple
CA-02	Aprobación: sin decisión de RRHH no se crea ningún ticket	Cumple
CA-03	Enrutamiento de los tipos de evento a las colas correctas	Cumple
CA-04	Los tickets programados nacen en estado «En espera»	Cumple
CA-05	Flujo de ingreso completo hasta el cierre	Cumple
CA-06	Emergencia con prioridad «Muy alta» y SLA de una hora	Cumple
CA-07	Resiliencia con GLPI detenido	Cumple
CA-08	Cierre verificado: sin solución no se cierra	Cumple
CA-09	Alterar la auditoría hace fallar su verificación	Cumple
CA-10	El motivo restringido no llega a GLPI	Cumple
CA-11	Detección de la caída de GLPI y de la base de datos	Cumple
CA-12	Pruebas de seguridad sin hallazgos explotables	Cumple
CA-13	La base de datos solo es accesible en su red interna y los roles públicos no tienen permisos	Cumple
CA-14	Contraseña correcta sin segundo factor no concede acceso	Cumple
CA-15	El panel coincide con su resultado esperado	Cumple
CA-16	Búsqueda y ficha correctas	Cumple
CA-17	La arquitectura se verifica automáticamente	Cumple
CA-18	Soporte de vinculación: solo PDF válido	Cumple
CA-19	El ticket de AD lista cada recurso compartido con ruta, perfil y grupo	Cumple
CA-20	El script de pruebas del WAF devuelve los códigos esperados	Cumple
CA-21	Un ataque se clasifica en la reportería en menos de dos minutos	Cumple

El criterio CA-13 se evaluó con la definición vigente del SRS 2.5, en la que la base de datos es un PostgreSQL 17 local: el contenedor no publica puertos y está en una red interna; los roles anon y authenticated no tienen privilegios sobre el esquema de la aplicación; el rol de la aplicación no puede modificar ni borrar la auditoría; y la clave de administración de Supabase no está en los contenedores web ni worker. En esa medición se aplicó a la base local la migración que activa la seguridad por filas en las tablas del framework (hallazgo B-23), que estaba pendiente.

8. Defectos funcionales detectados y corregidos

Las pruebas funcionales y la auditoría detectaron los siguientes defectos de funcionamiento. Cada uno se corrigió siguiendo la secuencia prueba en rojo, corrección mínima y prueba en verde, salvo el último, que permanece abierto.

Tabla 9. Defectos funcionales

Identificador	Defecto	Efecto	Estado
B-16	Tres scripts invocados por la integración continua no tenían permiso de ejecución	El trabajo contra GLPI real fallaba	Corregido
B-17	El adaptador de GLPI no detectaba que GLPI rechazara el vencimiento de un ticket	Tickets sin vencimiento, sin aviso	Corregido
B-19	La sincronización se detenía ante un error inesperado en una sola solicitud	Las demás solicitudes no se actualizaban	Corregido
B-20	Una respuesta inesperada de GLPI detenía la bandeja de salida	Bloqueo de los tickets siguientes	Corregido
B-24	La página del segundo factor respondía con error 500 si el servicio de autenticación fallaba	Mala experiencia ante una caída	Corregido
B-25	Una denegación por rol no dejaba rastro	Ausencia de trazabilidad	Corregido
B-37	La prueba de navegador podía aprobarse con tickets de una corrida anterior	Evidencia menos fiable	Abierto

9. Limitaciones

1. El servicio de autenticación real (Supabase Auth) no se ejercitó; se usó un servidor simulado y sesiones de prueba.
2. La integración continua en GitHub no se ejecutó sobre estos cambios. La copia de la auditoría y de los respaldos al disco externo se verificó con una carpeta que simula el disco, no con el disco real.
3. El recorrido con navegador cubre cuatro de los seis tipos de evento; los cambios de departamento y de sucursal se verifican con la suite automatizada y los escenarios.
4. La conformidad con las pautas de accesibilidad WCAG se verificó de forma mecánica (contraste y estructura), sin evaluación con tecnología de asistencia.

10. Conclusiones

1. El sistema cumple las funciones especificadas: los 21 criterios de aceptación se cumplen.
2. Los casos de uso principales funcionan de extremo a extremo a través del WAF, hasta los tickets en GLPI, con el contenido, la prioridad y el vencimiento previstos.
3. La verificación de las propias pruebas mediante mutación (92,7 % a 97,8 %) respalda que la suite detecta cambios en el comportamiento y no solo ejecuta el código.
4. Los defectos encontrados se corrigieron con su prueba de regresión; el único abierto afecta a la fiabilidad de una prueba, no al comportamiento del sistema.

11. Reproducibilidad

Las pruebas se reproducen con los comandos de la carpeta de evidencias de la auditoría (docs/entregables/auditoria): la suite con `make verificar`; los casos de uso contra GLPI real con `infra/scripts/contrato-glpi.sh`; y el recorrido con navegador con `infra/scripts/e2e-interfaz.sh`. Los resultados detallados se encuentran en las carpetas de evidencia funcional, con el comando, la salida, la versión de las herramientas y el commit.